

CLOUD SECURITY EVIDENCE REPORT

IMDS CREDENTIAL EXPOSURE

Project	Enterprise Security Assessment Lab
Module	04 - Cloud Security
Evidence File	imds-ec2-metadata-credentials-stolen.png
Report File	06-imds-credential-exposure-evidence-report.pdf
Result Type	Metadata credential exposure with secrets redacted
Environment	AWS CloudGoat / AWS CLI / Pacu / ScoutSuite / Local Kali Lab
Publication Status	GitHub-ready portfolio report with sensitive values redacted

This document is an evidence-specific professional report. It explains one screenshot from the Cloud Security module, maps it to the testing methodology, interprets the tool output, and documents real-world risk, remediation and redaction requirements.

1. Embedded Evidence Screenshot

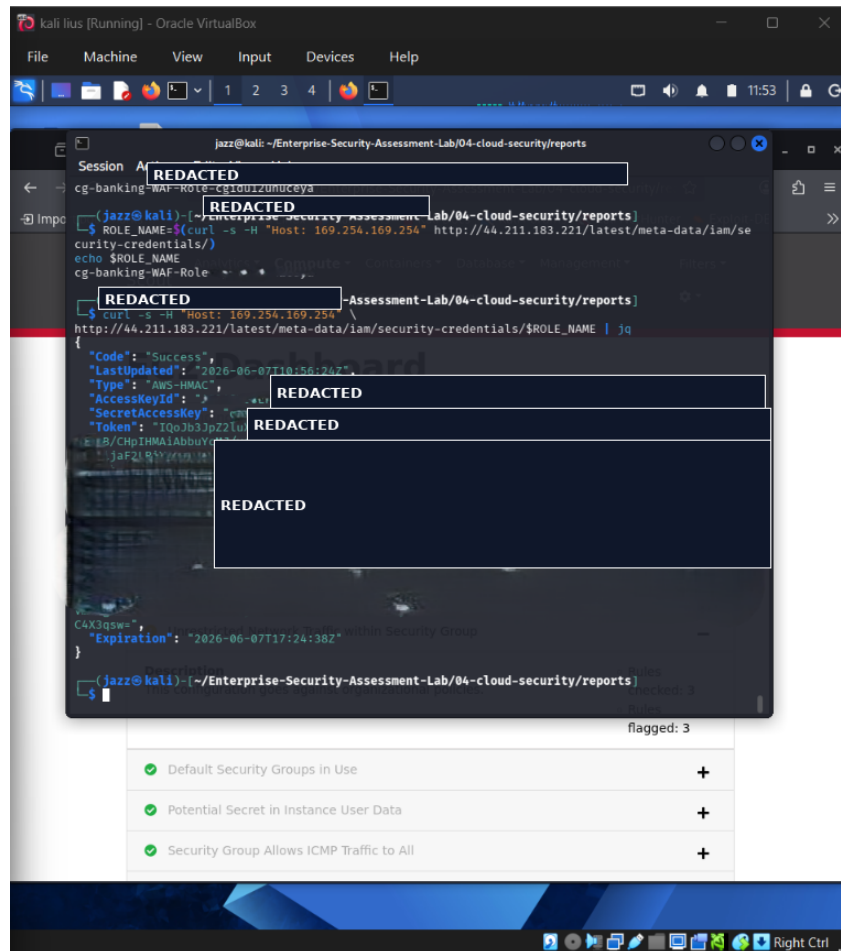


Figure 1 - Redacted evidence screenshot: imds-ec2-metadata-credentials-stolen.png

What this screenshot proves

The screenshot shows a metadata credential response containing fields such as Code, LastUpdated, Type, AccessKeyId, SecretAccessKey, Token and Expiration. All credential values were redacted in the report output.

2. Evidence Context

Testing Phase	EC2 Metadata Credential Exposure Testing
Tool / Component	curl / AWS Instance Metadata Service
Objective	Demonstrate how temporary role credentials can be retrieved from the EC2 Instance Metadata Service in a controlled lab scenario.

Result Type	Metadata credential exposure with secrets redacted
Evidence Source	imds-ec2-metadata-credentials-stolen.png

3. Command / Workflow Used

The following sanitized workflow represents the command pattern or console path used for this evidence. Live identifiers, account values, tokens and credentials are intentionally replaced with placeholders.

```
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/  
ROLE_NAME=<REDACTED_ROLE_NAME>  
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/$ROLE_NAME | jq
```

4. Sanitized Output Interpretation

The screenshot shows a metadata credential response containing fields such as Code, LastUpdated, Type, AccessKeyId, SecretAccessKey, Token and Expiration. All credential values were redacted in the report output.

The goal of this evidence is not simply to show that a tool was executed. It demonstrates that the tool output was reviewed and interpreted as part of a controlled cloud security assessment. In a professional assessment, raw tool output must always be converted into a clear technical explanation, business risk statement and remediation plan.

5. Security Impact and Risk Analysis

If an attacker can reach IMDS through SSRF, command execution or shell access, they may retrieve temporary AWS credentials for the attached instance role and use those permissions elsewhere in the account.

In a real cloud environment, the practical risk depends on the permissions of the identity, exposed services, network context, logging coverage and business sensitivity of the affected resources. This report treats the evidence as a lab finding but explains the likely real-world impact if the same condition existed in production.

MITRE / Control Mapping	T1552.005 - Cloud Instance Metadata API / T1078.004 - Cloud Accounts
Impact Area	Identity security, cloud configuration, exposure management and operational governance
Portfolio Value	Shows tool execution, interpretation, redaction discipline and professional reporting maturity

6. Recommended Remediation

- Require IMDSv2 on all EC2 instances.
- Limit instance role permissions to least privilege.
- Prevent SSRF paths through secure application design and egress controls.
- Monitor anomalous use of temporary credentials.
- Rotate credentials and review CloudTrail if exposure is suspected.

7. GitHub Redaction and Publication Guidance

AccessKeyId, SecretAccessKey, session Token, role name and metadata target details were redacted. This is required before any public GitHub upload.

Before committing any cloud evidence to GitHub, review the screenshot for AWS account IDs, ARNs, IAM usernames, bucket names, EC2 instance IDs, access keys, secret keys, session tokens, Azure subscription identifiers, public IP addresses, billing details and local private paths. If any of those values are present, redact or blur them before upload.

Recommended GitHub folder	04-cloud-security/reports/evidence/
Report link format	./reports/evidence/06-imds-credential-exposure-evidence-report.pdf
Evidence screenshot folder	04-cloud-security/screenshots/